CryptoMAKA: A Rigorous Evaluation Framework for Lightweight Three-Party Mutual Authentication and Key Agreement Protocols in Cloud-IoT Networks

Research Evaluation & Verification Group
CryptoMAKA Laboratory for Cybersecurity and Embedded Systems
Artifact Release v0.1.0 — Peer Review & Archival Preprint

***Abstract*—Mutual Authentication and Key Agreement (MAKA) protocols are foundational to secure edge-to-cloud IoT ecosystems. While numerous lightweight schemes claim low communication overhead and robust security, subtle bit-width ambiguities, replay vulnerabilities, and lack of real-world wireless evaluation undermine their practical adoption. This paper presents CryptoMAKA, a reproducible experimental testbed and formal verification suite. We implement a normalized, byte-aligned reconstruction of the recent Ju & Park (Sensors 2023) hash/XOR protocol alongside an authenticated Secp256r1 ECDH baseline and a post-quantum NIST FIPS 203 (ML-KEM-768) prototype. We verify security through both empirical adversary simulations (7 Dolev-Yao threat vectors) and formal mathematical proofs in Inria ProVerif 2.05 under applied pi-calculus, proving 100% secrecy and injective correspondence. Finally, we model cyber-physical channel dynamics across LPWAN (LoRaWAN) and cellular IoT (NB-IoT/LTE-M). Results demonstrate that while post-quantum KEMs provide theoretical quantum resistance, their large public keys and ciphertexts incur severe fragmentation penalties (96 packets on LoRaWAN DR0), validating the continued necessity of ultra-lightweight symmetric schemes for battery-constrained sensor nodes.**

***Index Terms*—Mutual Authentication, Key Agreement (MAKA), Cloud-IoT Security, ProVerif, Dolev-Yao Model, Post-Quantum Cryptography (ML-KEM-768), LoRaWAN, NB-IoT, Energy Modeling.**

I. INTRODUCTION

The explosion of Internet of Things (IoT) deployments in smart grids, industrial automation, and healthcare monitoring requires robust, end-to-end mutual authentication between edge devices and cloud service providers. In many three-party architectures, resource-constrained sensor nodes cannot directly verify cloud service certificates without an intermediary Control Server (CS) or Registration Centre (RC). To accommodate memory and battery limits, lightweight MAKA schemes rely primarily on one-way hash functions (SHA-256) and bitwise XOR operations rather than costly public-key exponentiations.

However, academic literature in this domain frequently suffers from two critical deficiencies: (1) *bit-width inconsistencies*, where published specifications combine 128-bit nonces with 256-bit hashes under XOR operations without formal normalization, and (2) *idealized evaluation*, where protocols are tested only on desktop CPUs without accounting for wireless radio transmission power, packet loss, and Maximum Transmission Unit (MTU) fragmentation over Low-Power Wide-Area Networks (LPWAN).

To resolve these challenges, we introduce **CryptoMAKA**, an open, reproducible framework that integrates bit-aligned protocol execution, automated adversarial testing, symbolic formal verification, and embedded energy modeling.

II. PROTOCOL ARCHITECTURES & NORMALIZATION

We evaluate four protocol configurations: (1) **Ju & Park (Sensors 2023)**: A three-party hash/XOR protocol using dynamic pseudonym rotation; (2) **ECC Baseline**: An authenticated ephemeral ECDH protocol over NIST Curve P-256; (3) **Reduced-RTT Extension**: An optimized protocol variant reducing message exchanges; and (4) **ML-KEM-768**: A post-quantum Key Encapsulation Mechanism following NIST FIPS 203.

Normalization Guarantee: In the original Ju-Park paper (Sensors 2023, Table 5), a communication cost of 3,776 bits is reported. However, expressions such as $(r_k \parallel r_i) \oplus H(\cdot)$ mix field widths. To eliminate implementation ambiguities, CryptoMAKA normalizes all pseudo-identities, nonces, and authenticators to 256-bit fixed-width SHA-256 blocks, resulting in an exact implementation wire cost of 4,224 bits.

Protocol Architecture	Security Paradigm	Published Reference	Implementation Cost	Flow Count
Ju & Park (Sensors 2023)	Symmetric (Hash/XOR)	3,776 bits (Table 5)	**4,224 bits (528 B)**	4 messages
ECC Baseline (Secp256r1)	Asymmetric (ECDH/P-256)	N/A (Counterpart)	**1,872 bits (234 B)**	2 messages

Reduced-RTT Extension	Symmetric (Optimized)	N/A (Proposed)	**3,616 bits (452 B)**	3 messages
ML-KEM-768 (NIST FIPS 203)	Post-Quantum (Module-Lattice)	N/A (FIPS 203)	**38,656 bits (4,832 B)**	4 messages

Table I: Cryptographic Communication Cost & Parameter Normalization Matrix.

III. THREAT MODEL & ADVERSARIAL PENETRATION SUITE

We adopt the standard **Dolev-Yao threat model**. An active adversary $\mathcal{A}$ has total eavesdropping and injection control over the public wireless channel. The automated regression test suite implements 7 concrete attack vectors against the protocol state machines:

Test ID	Threat Vector	Injected Fault / Action	Expected Outcome	Defense Mechanism
SEC-01	Replay Attack	Resend captured M1 post-session	**REJECT (unknown PID)**	Dynamic Pseudonym Rotation (PID_i^*)
SEC-02	Stale Timestamp	Inject $\|T_{cur} - TS\| > 30s$	**REJECT (stale timestamp)**	Freshness Window Verification ($\Delta T \le 30s$)
SEC-03	Parameter Tamper	Flip bit in masked nonce B_1	**REJECT (authenticator fail)**	SHA-256 Authenticator Binding (V_1)
SEC-04	User Impersonation	Forge M1 with arbitrary PID	**REJECT (invalid credentials)**	Registration Record Key Lookup
SEC-05	Cloud Spoofing	Rogue server transmits M2	**REJECT (cloud auth failed)**	Keyed Ticket Verification (k_j)
SEC-06	Nonce Reuse Check	Evaluate collision probability	**PASS (Zero collisions)**	OS CSPRNG (256-bit Entropy)
SEC-07	Key Convergence	Normal protocol exchange	**PASS ($SK_U == SK_S$)**	Symmetric Key Agreement Evaluation

Table II: Automated Dolev-Yao Adversary Threat Regression Evaluation Matrix.

IV. FORMAL PROTOCOL VERIFICATION (PROVERIF 2.05)

While empirical penetration testing verifies software correctness under specific test inputs, it does not constitute mathematical proof. To prove protocol security over an *unbounded number of interleaved concurrent sessions*, we authored applied pi-calculus models in Inria ProVerif 2.05+ for Ju-Park, ECC, and ML-KEM-768.

Protocol	Theorems	Secrecy Proof	Injective Mutual Authentication	Replay Immunity
Ju & Park (Sensors 2023)	5/5 Proved	**TRUE** (not attacker(SK))	**TRUE** (inj-event correspondence)	**VERIFIED (Zero Replays)**
ECC Baseline (Secp256r1)	4/4 Proved	**TRUE** (not attacker(SK))	**TRUE** (inj-event correspondence)	**VERIFIED (Zero Replays)**
Post-Quantum ML-KEM-768 (NIST FIPS 203)	4/4 Proved	**TRUE** (not attacker(SK))	**TRUE** (inj-event correspondence)	**VERIFIED (Zero Replays)**

Table III: Formal ProVerif 2.05 Verification Summary in the Applied Pi-Calculus.

V. CYBER-PHYSICAL IOT WIRELESS & ENERGY MODELING

A core innovation of CryptoMAKA is our cyber-physical simulation engine. In real IoT networks, communication delay and radio transceiver power dominate CPU execution time by orders of magnitude. We model message fragmentation over standard LPWAN (LoRaWAN EU868 DR0/DR3 with 51B/115B MTUs) and cellular IoT (NB-IoT Cat-NB1 with 350ms RTT), calibrated to an ARM Cortex-M4 microcontroller running at 3.0V with a standard CR2032 coin cell (220 mAh = 2,376 J).

Protocol	NB-IoT Latency	LoRa DR0 Latency	LoRa DR0 Pkts	Handshake Energy	Battery Life (CR2032)
Ju-Park 2023	595.5 ms	24.18 s	11 pkts	**32.07 mJ**	**4.95 Years**
ECC P-256	433.7 ms	11.44 s	6 pkts	**22.20 mJ**	**6.04 Years**
Reduced-RTT	395.3 ms	15.25 s	7 pkts	**21.27 mJ**	**6.17 Years**
ML-KEM-768 (PQC)	1328.6 ms	218.43 s (3.6m)	**96 pkts**	**71.33 mJ**	**2.88 Years**

Table IV: Cyber-Physical Wireless Channel Latency, MTU Fragmentation, and Battery Lifespan Projections.

VI. DISCUSSION & CONCLUSION

Our results reveal a pivotal architectural insight: while post-quantum lattice cryptography (ML-KEM-768) is essential for long-term quantum security, its 4.8 KB wire footprint causes disastrous fragmentation over constrained LPWAN links (requiring 96 packet fragments on LoRaWAN DR0, causing a 218-second handshake delay and risking regulatory duty-cycle violation). Consequently, ultra-lightweight symmetric schemes such as Ju & Park remain uniquely suited for power-constrained edge sensors, extending coin-cell operational life by nearly 87% over post-quantum alternatives. CryptoMAKA provides an extensible, rigorously audited open-source foundation for future protocol benchmarking and standardization.

REFERENCES

[1] C. Ju and N. Park, "An efficient lightweight three-party authentication and key agreement protocol for cloud-assisted IoT environments," Sensors, vol. 23, no. 24, p. 9766, 2023.
[2] B. Blanchet, "Modeling and verifying security protocols with the applied pi calculus and ProVerif," Foundations and Trends in Privacy and Security, vol. 1, no. 1–2, pp. 1–135, 2016.
[3] NIST, "Module-Lattice-Based Key-Encapsulation Mechanism Standard," FIPS PUB 203, National Institute of Standards and Technology, Aug. 2024.
[4] D. Dolev and A. C. Yao, "On the security of public key protocols," IEEE Transactions on Information Theory, vol. 29, no. 2, pp. 198–208, 1983.
[5] 3GPP, "Cellular system support for ultra-low complexity and low throughput Internet of Things (CIoT)," 3GPP TR 45.820 v13.1.0, Nov. 2015.